ACP Assessment Questionnaire

This questionnaire supports assessors and organizations in performing an **Active Cyber Program (ACP) Assessment** or self-assessment.

Each row corresponds to one control of the ACP assessment checklist (`assessment/assessment-checklist.md`). The guiding questions help determine **one score per control**. Questions are not scored individually.

Framework version: **ACP 1.5**

How to Use

1. Confirm the assessment scope and whether the AI Security domain (Domain 11) is applicable.
2. For each control, work through the guiding questions with the responsible persons.
3. Record the evidence reviewed (document name, system, screenshot, interview).
4. Assign one score per control. Use N/A only where permitted by the scoring model.
5. Calculate domain scores and the overall ACP score as defined in `assessment/scoring-model.md`.

Score	Meaning	Description
0	Not Implemented	The control does not exist, is not implemented, or no evidence is provided.
1	Partially Implemented	The control exists but is incomplete, inconsistently applied, or covers only part of the scope.
2	Implemented	The control is implemented across the scope, documented, and evidence shows that it is operating.
3	Actively Managed	In addition, the control is monitored, reviewed at defined intervals and improved over time.

Controls marked **[KO]** are knock-out controls. A score of 0 prevents certification. Knock-out controls cannot be marked N/A.

Assessment Information

Organization:

Assessment date:

Assessor:

AI Security domain applicable: □ Yes □ No

Domain 1 – Business & Security Governance (critical)

ID	Control	Guiding questions	Score	Evidence / Notes
1.1	A cybersecurity strategy is documented	• Is a documented cybersecurity or information security strategy in place? • Has the strategy been approved by executive management? • When was the strategy last reviewed?		
1.2	Cybersecurity objectives are defined and aligned with business goals	• Are cybersecurity objectives defined and documented? • Are the objectives derived from business goals? • Are the objectives reviewed regularly?		
1.3	Security responsibilities are assigned within the organization	• Are responsibilities for cybersecurity defined? • Is a person accountable for cybersecurity named (e.g., CISO, information security officer)? • Are deputies defined?		
1.4	Security topics are discussed at management level	• Are cybersecurity topics discussed regularly in management meetings? • Are decisions on cybersecurity documented?		
1.5	Security initiatives are planned and tracked	• Is there a roadmap for security measures? • Do measures have owners, budgets and deadlines? • Is progress tracked?		
1.6	Security reporting to leadership exists	• Does management receive regular security reports? • Are the results of security assessments communicated to management?		

Domain score:

Domain 2 – Risk Management

ID	Control	Guiding questions	Score	Evidence / Notes
2.1	Cybersecurity risks are formally identified	• Is there a process to identify cybersecurity risks? • Are risks reassessed when systems or processes change? • Are cloud risks considered?		
2.2	A risk register exists	• Is a risk register maintained? • Does each risk have an owner?		
2.3	Risks are evaluated based on impact and likelihood	• Is a documented risk assessment methodology in place? • Are risks rated by likelihood and impact?		
2.4	Risk mitigation measures are defined	• Are mitigation measures defined for relevant risks? • Are measures tracked to completion? • Is the acceptance of residual risks formally approved?		
2.5	Risk reviews are conducted periodically	• Are risks reviewed at defined intervals? • When was the last review performed?		
2.6	Supply chain risks are assessed and security requirements are agreed with critical suppliers	• Are critical suppliers and service providers identified? • Are their security risks and practices assessed before and during the relationship, including secure development practices of software suppliers? • Are security requirements included in contracts with critical suppliers?		

Domain score:

Domain 3 – Security Policies & Processes

ID	Control	Guiding questions	Score	Evidence / Notes
3.1	An information security policy exists	• Is an information security policy documented and accessible? • Has it been approved by management? • Is it reviewed regularly?		
3.2	Acceptable use policies are defined	• Is an acceptable use policy in place? • Are rules for the use of IT systems and cloud services defined?		
3.3	Backup policies are documented	• Is a backup policy in place? • Does it define scope, frequency, retention and restore responsibilities?		
3.4	Patch management procedures exist	• Is a patch management process defined? • Does it define timelines based on severity?		
3.5	Incident response procedures are defined	• Is an incident response procedure documented? • Does it define roles, reporting channels and notification obligations?		
3.6	Security responsibilities are agreed with employees, and security procedures are communicated to them	• Are security responsibilities and confidentiality obligations included in employment contracts or separate agreements? • Are background checks performed for roles with access to sensitive information, where legally permitted? • Are employees informed about security policies and procedures, and do they confirm that they have read them?		

Domain score:

Domain 4 – Identity & Access Management (critical)

ID	Control	Guiding questions	Score	Evidence / Notes
4.1	User account management is controlled	• Is there a defined process for creating, changing and removing user accounts? • Are all accounts personal (no shared accounts)?		
4.2	Role-based access control is implemented	• Are access rights assigned based on roles? • Is the principle of least privilege applied?		
4.3	Multi-factor authentication is used for remote access, cloud services and administrative accounts **[KO]**	• Is MFA enforced for remote access, cloud services and email? • Is MFA enforced for all administrative accounts? • Are exceptions documented and approved?		
4.4	Privileged accounts are restricted and monitored **[KO]**	• Are privileged accounts separated from everyday user accounts? • Is the number of privileged accounts limited? • Is privileged activity logged and reviewed?		
4.5	Access rights are reviewed periodically	• Are access rights reviewed at defined intervals? • Are review results documented and corrections implemented?		
4.6	User accounts are removed when employees leave	• Are accounts disabled promptly when employees leave or change roles? • Is the process linked to HR?		

Domain score:

Domain 5 – Infrastructure Security

ID	Control	Guiding questions	Score	Evidence / Notes
5.1	An inventory of systems and servers exists	• Is an inventory of servers, systems and cloud resources maintained? • Is it current, and does each system have an owner?		
5.2	Secure configuration standards are defined	• Are secure configuration standards (hardening baselines) defined? • Are they based on recognized benchmarks (e.g., CIS Benchmarks)? • Is compliance with the standards checked?		
5.3	Systems are regularly patched and updated **[KO]**	• Are security updates applied within defined timeframes? • Are critical vulnerabilities patched with priority? • Are unsupported systems identified and handled?		
5.4	Administrative access to systems is restricted	• Is administrative access restricted to authorized personnel and dedicated access paths? • Are administrative interfaces protected from direct internet access?		
5.5	System and software changes are documented and approved, following secure development practices where software is developed or commissioned	• Are changes to systems and software documented and approved? • Is a change management process in place? • If software is developed in-house or commissioned: are secure development practices defined (e.g., secure coding, security testing, separation of development and production)?		
5.6	Cloud infrastructure follows secure configuration practices	• Are cloud environments configured according to security best practices? • Is the cloud security posture monitored (e.g., secure score, posture management)?		

Domain score:

Domain 6 – Endpoint Security

ID	Control	Guiding questions	Score	Evidence / Notes
6.1	Endpoint protection software is deployed	• Is endpoint protection (antivirus or EDR) deployed on all endpoints? • Is its status monitored centrally?		
6.2	Devices are centrally managed	• Are devices centrally managed (e.g., MDM/UEM)? • Are compliance policies enforced?		
6.3	Disk encryption is enabled on endpoints	• Is disk encryption enabled on all laptops and desktops? • Are recovery keys stored securely?		
6.4	Endpoint updates are automatically deployed	• Are operating system and application updates deployed automatically? • Is update compliance monitored?		
6.5	Mobile devices are managed securely	• Are mobile devices managed? • Is company data on personal devices protected?		
6.6	Lost or stolen devices can be remotely controlled or wiped	• Can lost or stolen devices be locked or wiped remotely? • Is there a process for reporting lost devices?		

Domain score:

Domain 7 – Network Security

ID	Control	Guiding questions	Score	Evidence / Notes
7.1	Network firewalls are implemented	• Are firewalls deployed at network perimeters? • Are firewall rules reviewed regularly?		
7.2	Network segmentation is used where appropriate	• Are networks segmented (e.g., servers, clients, guests)? • Are critical systems isolated?		
7.3	Secure remote access (e.g., VPN or Zero Trust Network Access) is implemented	• Is remote access provided through secure solutions (VPN or ZTNA)? • Is remote access limited to authorized users and devices?		
7.4	Network traffic monitoring is performed	• Is network traffic monitored for suspicious activity? • Are intrusion detection or prevention systems used?		
7.5	Wireless networks are securely configured	• Are wireless networks secured with current encryption (e.g., WPA2/WPA3 Enterprise)? • Is guest Wi-Fi separated from internal networks?		
7.6	Network access is restricted to authorized devices	• Is network access restricted to authorized devices (e.g., NAC, 802.1X)? • Are unknown devices detected?		

Domain score:

Domain 8 – Data Protection, Backup & Recovery (critical)

ID	Control	Guiding questions	Score	Evidence / Notes
8.1	Sensitive data is identified and classified	• Is sensitive data identified? • Is a data classification scheme in place and applied?		
8.2	Encryption is used to protect sensitive data based on a defined cryptography policy	• Is a cryptography policy defined (e.g., approved algorithms, key lengths, key management)? • Is sensitive data encrypted at rest and in transit according to this policy? • Are encryption keys managed securely?		
8.3	Secure file transfer mechanisms are used	• Are secure file transfer methods used (e.g., SFTP, secure sharing platforms)? • Are insecure transfer methods prohibited?		
8.4	Backup procedures are implemented and tested **[KO]**	• Are backups performed according to the backup policy? • Are restores tested regularly and documented?		
8.5	Backup data is protected from unauthorized access and tampering **[KO]**	• Are backups protected against unauthorized access and ransomware (e.g., offline or immutable copies, separate credentials)? • Is at least one backup copy stored at a separate location?		
8.6	Files exchanged or archived outside protected systems are encrypted using current algorithms (e.g., AES-256)	• Are files exchanged or archived outside protected systems encrypted? • Are current algorithms used (e.g., AES-256)?		
8.7	Business continuity and disaster recovery plans are documented and tested	• Are critical business processes and IT systems identified, with recovery time and recovery point objectives (RTO/RPO)? • Are business continuity and disaster recovery plans documented for these processes and systems? • Are the plans tested regularly (e.g., recovery tests, tabletop exercises), and are the results documented?		
8.8	Crisis management and emergency communication are defined	• Is a crisis management team with roles and decision authority defined? • Are emergency communication channels defined that work when primary IT systems are unavailable? • Are contact lists for internal and external parties (e.g., authorities, insurers, key suppliers) current?		

Domain score:

Domain 9 – Monitoring & Incident Response (critical)

ID	Control	Guiding questions	Score	Evidence / Notes
9.1	Security logs are collected	• Are security logs collected from relevant systems? • Are logs stored centrally and retained for a defined period?		
9.2	Log monitoring is performed	• Are logs monitored? • Is monitoring automated (e.g., SIEM)?		
9.3	Security alerts are reviewed regularly	• Are security alerts reviewed regularly? • Are responsibilities and response times defined?		
9.4	Incident response procedures are documented and operational **[KO]**	• Is an incident response procedure documented and known to responsible staff? • Has it been tested (e.g., tabletop exercise)?		
9.5	Security incidents are recorded and investigated	• Are security incidents recorded and investigated? • Are root causes analyzed and lessons learned documented?		
9.6	Incident escalation and reporting paths, including regulatory reporting obligations, are defined	• Are escalation paths defined, including management and external parties? • Are applicable regulatory reporting obligations and deadlines known (e.g., NIS2: early warning within 24 hours, incident notification within 72 hours, final report within one month)? • Is it defined who reports to authorities and how?		

Domain score:

Domain 10 – Continuous Improvement

ID	Control	Guiding questions	Score	Evidence / Notes
10.1	Security reviews are conducted periodically	• Are security reviews conducted at defined intervals? • Are the results documented?		
10.2	Security audits or assessments are performed	• Are internal or external security audits performed? • Are findings tracked?		
10.3	Vulnerabilities are identified through regular assessments, and reported vulnerabilities are handled	• Are vulnerability scans or penetration tests conducted regularly? • Are findings remediated? • Is there a process for receiving and handling vulnerability reports from external parties (e.g., security contact, vulnerability disclosure policy)?		
10.4	Improvement actions are tracked	• Are improvement actions tracked with owners and deadlines? • Is progress reported?		
10.5	Security awareness training is provided to employees and management	• Do all employees receive security awareness training? • Do members of management receive cybersecurity training (e.g., as required by NIS2 Art. 20(2))? • Are phishing simulations conducted, and is participation tracked?		
10.6	Security metrics or KPIs are evaluated	• Are security metrics or KPIs defined? • Are they evaluated and reported?		

Domain score:

Domain 11 – AI Security (if applicable; critical when applicable)

ID	Control	Guiding questions	Score	Evidence / Notes
11.1	AI systems are identified and inventoried, with defined owners	• Are AI systems and AI services in use identified and inventoried? • Does each AI system have a defined owner?		
11.2	AI security risks are assessed	• Are AI-specific risks assessed (e.g., data leakage, prompt injection, model manipulation)? • Are regulatory requirements (e.g., EU AI Act) considered?		
11.3	AI usage policies and security controls are defined and implemented	• Are AI usage policies defined and communicated? • Are technical guardrails and access controls implemented for AI systems?		
11.4	AI systems are monitored for security events and unexpected behavior	• Are AI systems monitored for security events? • Is unexpected behavior detected and reviewed?		
11.5	AI security incidents are investigated	• Are AI-related security incidents recorded and investigated?		
11.6	AI security is included in management reporting and continuous improvement	• Is AI security included in management reporting? • Is AI security part of continuous improvement activities?		

Domain score:

Result Summary

Domain	Critical	Score
1. Business & Security Governance	Yes	
2. Risk Management		
3. Security Policies & Processes		
4. Identity & Access Management	Yes	
5. Infrastructure Security		
6. Endpoint Security		
7. Network Security		
8. Data Protection, Backup & Recovery	Yes	
9. Monitoring & Incident Response	Yes	
10. Continuous Improvement		
11. AI Security (if applicable)	Yes	

Overall ACP score:

ACP maturity level:

Knock-out control scored 0: □ No □ Yes (ID:)